HACKATHON CYBERSÉCURITÉ — JUIN 2025

Rapport d'Audit Sécurité

Défense en profondeur d'un réseau IT fictif

OPNsense · Wazuh · Fail2Ban · Nessus · Exegol · OpenVPN

Chef de projet **Hackathon Cybersécurité 2025**

10 – 27 juin 2025

Présentation finale : 27 juin 2025

1. Introduction . . . 3
2. Cahier des charges . . . 3
2.1. Objectif du projet . . . 3
2.2. Contexte & besoins . . . 3
2.3. Environnement technique . . . 3
2.3.1. Plateforme : VMware Workstation Pro . . . 3
2.3.2. Plan d'adressage IP . . . 3
2.4. Répartition des tâches . . . 4
2.5. Planning prévisionnel . . . 4
2.6. Sécurité & supervision . . . 4
2.7. Livrables . . . 4
2.8. Suivi & Méthodologie . . . 5
3. Déploiement et configuration . . . 5
3.1. Phase 1 — Mise en place de l'environnement (10–16 juin) . . . 5
3.1.1. Objectifs . . . 5
3.1.2. Schéma réseau . . . 5
3.1.3. Justification des interfaces VMware . . . 5
3.1.4. PC 1 — Kali Linux + Nessus + Exegol . . . 6
3.1.5. PC 2 — Ubuntu Hardened + Wazuh . . . 6
3.1.6. PC 3 — OPNsense . . . 10
3.1.7. PC 4 — Client VPN Ubuntu . . . 11
3.2. Checklist Phase 1 — État final . . . 11
3.3. Sources officielles . . . 12
3.4. Phase 2 — Sécurisation, supervision & tests d'attaque (16–20 juin) . . . 12
3.4.1. Objectifs globaux . . . 12
3.4.2. PC 1 — Red Team (Kali + Nessus + Exegol) . . . 12
3.4.3. PC 2 — Supervision et hardening . . . 14
3.4.4. PC 3 — OPNsense IDS/IPS . . . 15
3.5. Checklist Phase 2 — État final . . . 15
4. Conclusion . . . 15

Introduction

Ce rapport documente le projet de cybersécurité réalisé dans le cadre d'un hackathon du **10 au 26 juin 2025**, avec une présentation finale le **27 juin**.

L'objectif est de mettre en œuvre une **défense en profondeur** pour un environnement IT fictif en s'appuyant sur des outils open source : **OPNsense**, **Wazuh**, **Fail2Ban**, **Nessus**, **Exegol** et **OpenVPN**.

Durée du projet
10 au 26 juin 2025
Présentation le 27 juin

Résultat global
Tous les objectifs techniques atteints ;
>90 % des vulnérabilités corrigées

Cahier des charges

Objectif du projet

Auditer, sécuriser et superviser l'environnement IT d'une entreprise fictive : détecter les failles, mettre en place une défense en profondeur, tester les accès VPN et documenter l'ensemble des configurations.

Contexte & besoins

L'entreprise souhaite :

- Protéger ses serveurs exposés (web, SSH…)
- Contrôler les accès distants (SSH, VPN admin)
- Mettre en place un système de détection d'intrusion (IDS)
- Suivre les logs de sécurité en temps réel
- Appliquer une politique de sécurité cohérente
- Tester la robustesse via attaques internes & externes

Environnement technique

› Plateforme : VMware Workstation Pro

- Simulation complète d'un réseau entreprise (LAN, WAN, VPN)
- Configuration fine des interfaces : Bridged, NAT, Host-only
- Snapshots et rollback pour les tests de sécurité

› Plan d'adressage IP

Hôte	Rôle	IP	Interface VMware
OPNsense	Firewall & VPN	192.168.10.254	VMnet1 + Bridged

Hôte	Rôle	IP	Interface VMware
Ubuntu Hardened	Serveur cible sécurisé	192.168.10.10	VMnet1 + NAT
Wazuh Manager	IDS / SIEM	192.168.10.20	VMnet1 + NAT
Kali Linux	Red Team + Nessus	192.168.10.50	VMnet1 + Bridged
Client VPN Ubuntu	Accès distant VPN	192.168.10.60 VPN	NAT + tunnel

Répartition des tâches

Outil	Périmètre
OPNsense	Déploiement firewall, NAT, règles, VPN
Ubuntu Hardened	UFW, SSH, Fail2Ban, sysctl
Wazuh Manager	Installation, agents, alertes, dashboard
Kali Red Team	Scan réseau, brute-force, Exegol, Nessus
VPN	Configuration serveur OpenVPN + client test
Rapport final	Rédaction, captures, analyse globale

Planning prévisionnel

Phase	Dates
Déploiement & réseau	10 – 16 juin
Pare-feu & IDS	16 – 18 juin
Attaques, scans & hardening	19 – 24 juin
Analyse & documentation	20 – 26 juin
Répétition & finalisation	25 – 27 juin

Sécurité & supervision

- **Pare-feu OPNsense** : filtrage, NAT, VPN, journalisation
- **IDS Wazuh** avec agent sur Ubuntu Hardened
- **Hardening système** : Fail2Ban, SSH par clé, désactivation root, sysctl
- **Connexions VPN** loggées et accès au SI vérifié

Livrables

Livrable	Format
Rapport technique	PDF + HackMD
Scripts & configs	.sh / .conf
Exports OPNsense	XML + captures

Livrable	Format
Rapports Nessus	HTML, PDF
Guide VPN & sécurité	Markdown

Suivi & Méthodologie

- **Suivi centralisé HackMD** : checklist à jour, notes journalières, documentation collaborative
- **Réunions bi-quotidiennes** (matin & après-midi, 15 min) : avancement, blocages, priorisation
- **Preuves d'audit** : captures (IDS, pare-feu, scans), exports de configs, démonstrations orales

Dernière mise à jour : 27 juin 2025 – 10:00

Déploiement et configuration

Phase 1 — Mise en place de l'environnement (10–16 juin)

› Objectifs

- Déployer un environnement de cybersécurité simulé sur 4 postes physiques
- Connecter les VMs via 2 réseaux : LAN isolé (`192.168.10.X`) et WAN NAT (`10.40.10.X`)
- Assigner chaque VM à son rôle, interface et IP
- Réaliser toutes les installations logicielles nécessaires
- Vérifier la connectivité et les services (ping, web, VPN)

› Schéma réseau

VM	Rôle réseau	Interface	IP	Segment
OPNsense (le0)	Firewall WAN	Bridged	DHCP 10.40.10.X	WAN
OPNsense (le1)	Firewall LAN	VMnet1 Host-only	192.168.10.254	LAN
Ubuntu Hardened	Serveur sécurisé	VMnet1 Host-only	192.168.10.10	LAN
Wazuh Manager	IDS / SIEM	VMnet1 Host-only	192.168.10.20	LAN
Kali Linux (interne)	Attaques internes	VMnet1 Host-only	192.168.10.50	LAN
Kali Linux (externe)	Scans Nessus externes	Bridged	DHCP 10.40.10.X	WAN
Client VPN Ubuntu	Accès distant VPN	NAT	192.168.10.60	via tunnel

› Justification des interfaces VMware

- **Bridged** : OPNsense et Kali accèdent au réseau physique (10.40.10.X)
- **VMnet1 (Host-only)** : LAN isolé, contrôlé exclusivement par OPNsense
- **NAT** : réservé au client VPN pour simuler un accès externe

—

› PC 1 — Kali Linux + Nessus + Exegol

Interfaces : `eth0` → Bridged/DHCP WAN | `eth1` → VMnet1 `192.168.10.50/24`

Configuration de l'interface LAN

```
sudo nmcli con add type ethernet con-name LAN ifname eth1 \
  autoconnect yes ip4 192.168.10.50/24 gw4 192.168.10.254
sudo nmcli con mod LAN ipv4.dns "8.8.8.8"
sudo nmcli con up LAN
```

Installation de Nessus

Télécharger sur https://www.tenable.com/downloads/nessus puis :

```
sudo dpkg -i Nessus-*.deb
sudo systemctl start nessusd
# Interface web : https://localhost:8834
```

Installation officielle d'Exegol

```
# 1. Dépendances
sudo apt update
sudo apt install apt-transport-https ca-certificates curl gnupg lsb-release -y

# 2. Docker
curl -fsSL "https://get.docker.com/" | sh
sudo systemctl start docker && sudo systemctl enable docker
sudo usermod -aG docker $USER  # optionnel : Docker sans sudo

# 3. Exegol
pipx install exegol
exegol activate
exegol install
```

—

› PC 2 — Ubuntu Hardened + Wazuh

Objectif : Serveur Ubuntu durci + déploiement Wazuh IDS.

Configuration réseau Netplan

```
# /etc/netplan/00-installer-config.yaml
network:
  version: 2
  ethernets:
```

```
    ens33:              # NAT - accès Internet
      dhcp4: true
      optional: true
    ens37:              # Host-only - LAN local
      addresses: [192.168.10.10/24]
      gateway4: 192.168.10.254
      nameservers:
        addresses: [8.8.8.8]
```

```
sudo netplan try && sudo netplan apply
ip a
```

Hardening du système

```
sudo apt update && sudo apt upgrade -y
sudo apt install apparmor apparmor-profiles apparmor-utils auditd -y
sudo systemctl enable --now apparmor

# Mises à jour automatiques
sudo apt install unattended-upgrades
sudo dpkg-reconfigure --priority=low unattended-upgrades
```

Durcissement noyau (sysctl)

```
sudo nano /etc/sysctl.d/99-hardening.conf
```

```
net.ipv4.ip_forward = 0
net.ipv4.conf.all.send_redirects = 0
net.ipv4.conf.all.accept_source_route = 0
net.ipv4.conf.all.accept_redirects = 0
net.ipv4.conf.all.rp_filter = 1
```

```
sudo sysctl --system
```

Configuration SSH sécurisée

```
sudo apt install openssh-server -y
sudo nano /etc/ssh/sshd_config
```

```
PermitRootLogin no
PasswordAuthentication no
Port 22
```

```
# Générer une paire RSA si absente
ls ~/.ssh/id_rsa.pub || ssh-keygen -t rsa -b 4096
```

```
# Configurer authorized_keys
mkdir -p ~/.ssh && chmod 700 ~/.ssh
nano ~/.ssh/authorized_keys && chmod 600 ~/.ssh/authorized_keys

# Tester
ssh -i ~/.ssh/id_rsa -p 22 user@192.168.10.10
```

UFW (pare-feu local)

```
sudo apt install ufw -y
sudo ufw default deny incoming
sudo ufw default allow outgoing
sudo ufw allow 22/tcp
sudo ufw enable && sudo ufw status verbose
```

Fail2Ban

```
sudo apt install fail2ban -y
sudo systemctl enable --now fail2ban
sudo systemctl status fail2ban
```

Wazuh Manager — Installation

```
# Télécharger et lancer le script (5 à 15 min)
curl -sO https://packages.wazuh.com/4.7/wazuh-install.sh
sudo bash ./wazuh-install.sh -a -i

# Vérifier le service
sudo systemctl status wazuh-manager
# Attendu : active (running)
```

Dashboard disponible sur : `https://192.168.10.20:443` — identifiants affichés en fin d'installation.

Certificat auto-signé : cliquer sur **Avancé** > **Continuer** lors du premier accès.

```
# UFW optionnel sur le Manager
sudo ufw default deny incoming && sudo ufw default allow outgoing
sudo ufw allow 22/tcp && sudo ufw enable
```

Wazuh Agent — Installation (sur Ubuntu Hardened)

```
# 1. Installer l'agent
wget https://packages.wazuh.com/4.x/apt/pool/main/w/wazuh-agent/wazuh-agent_4.7.5-1_amd
64.deb
sudo WAZUH_MANAGER='192.168.10.20' \
     WAZUH_AGENT_NAME='agent-01' \
     dpkg -i ./wazuh-agent_4.7.5-1_amd64.deb
```

```
# 2. Manager : ajouter l'agent (A=Add, E=Extract key, L=List)
sudo /var/ossec/bin/manage_agents

# 3. Agent : importer la clé (I=Import)
sudo /var/ossec/bin/manage_agents

# 4. Authentification et démarrage
sudo /var/ossec/bin/agent-auth -m 192.168.10.20 -A agent-01
sudo systemctl restart wazuh-agent && sudo systemctl daemon-reload

# 5. Contrôle
sudo systemctl status wazuh-agent
sudo /var/ossec/bin/agent_control -l

# 6. Tests réseau si problème
telnet 192.168.10.20 1514
nc -vz 192.168.10.20 1514
```

✅ Si l'agent est **active** dans Wazuh > Agents, la configuration est correcte.

⚠️ Si **never connected** : recommencer depuis la création de clé côté manager.

Récapitulatif des commandes Wazuh

Action	Commande	Côté	Note
Lister les agents	`/var/ossec/bin/agent_control -l`	Manager	Liste + statut
Logs en direct	`tail -f /var/ossec/logs/ossec.log`	Agent	Connexion / erreurs
Test connexion	`grep "Connected to the server" /var/ossec/logs/ossec.log`	Agent	Établissement
Test TCP	`nc -vz 192.168.10.20 1514`	Agent	Port Wazuh
Test Telnet	`telnet 192.168.10.20 1514`	Agent	Alternative
Restart agent	`systemctl restart wazuh-agent`	Agent	Appliquer modifs
Reload systemd	`systemctl daemon-reexec && systemctl daemon-reload`	Agent	Recharge services
Lire ossec.conf	`cat /var/ossec/etc/ossec.conf`	Agent	IP/port manager

Compatibilité Agent / Manager / Dashboard

```
# Vérifier les versions
sudo /var/ossec/bin/wazuh-control info
dpkg -l | grep wazuh-dashboard
```

Mise à jour du dashboard (ex. 4.7.5 → 4.12.0) :

```
sudo cp -r /etc/wazuh-dashboard /etc/wazuh-dashboard.bak
sudo apt update && sudo apt install wazuh-dashboard=4.12.0-1
sudo dpkg --configure -a
sudo systemctl restart wazuh-dashboard
```

Script d'automatisation redémarrage agent

```
sudo nano /home/user/reconnect_wazuh_agent.sh
```

```
#!/bin/bash
echo "[$(date)] Script lance." >> /var/log/wazuh_reconnect.log 2>&1
sudo systemctl status wazuh-agent
sudo systemctl restart wazuh-agent
ping -c 3 192.168.10.20
nc -zv 192.168.10.20 1514 || echo "WARN: port 1514 inaccessible"
sudo systemctl restart wazuh-agent
sudo tail -n 20 /var/ossec/logs/ossec.log
echo "[$(date)] Agent redemarre." >> /var/log/wazuh_reconnect.log 2>&1
echo "OK: verifiez le dashboard Wazuh."
```

```
chmod +x /home/user/reconnect_wazuh_agent.sh
# Lancer au demarrage via crontab root :
# @reboot /home/user/reconnect_wazuh_agent.sh
```

—

› PC 3 — OPNsense

Interfaces : `le0` → WAN Bridged DHCP | `le1` → LAN VMnet1 `192.168.10.254/24`

Accès web : `https://192.168.10.254` (login : `root`, mdp : `opnsense` par défaut)

Configuration via System Wizard

L'assistant guide la configuration initiale : hostname, DNS, interfaces WAN/LAN, mot de passe admin. Le DHCP LAN est activé sur `192.168.10.100–199`.

Règles pare-feu

Protocole	Port	Règle
TCP	80/443	HTTP/HTTPS — LAN → WAN
TCP	22	SSH — LAN uniquement
ICMP	—	Ping — tests de connectivité

NAT automatique activé vers `le0` (masquerade).

IDS/IPS avec Suricata

- Interface : **LAN**
- Règles : `emerging-ssh`, `emerging-dos`, `emerging-scan`
- Alertes : **Services** > **Intrusion Detection** > **Alerts**
- Logs live : **Firewall** > **Logs** > **Live View**

—

› PC 4 — Client VPN Ubuntu

Objectif : Simuler un accès distant sécurisé au LAN via OpenVPN.

Étapes OPNsense :

1. Créer le CA — **System** > **Trust** > **Authorities**
2. Créer le certificat serveur — **System** > **Trust** > **Certificates**
3. Créer un utilisateur VPN — **System** > **Access** > **Users**
4. Configurer le serveur OpenVPN — **VPN** > **OpenVPN** > **Servers**
5. Règles pare-feu — autoriser UDP `1194` et trafic tunnel
6. Exporter le profil client — **VPN** > **OpenVPN** > **Client Export**

```
# Client Ubuntu
sudo apt update && sudo apt upgrade -y
sudo apt install openvpn network-manager-openvpn -y
sudo openvpn --config client.ovpn
```

```
# Tests d'accès internes
ping 192.168.10.10        # Ubuntu Hardened
ping 192.168.10.20        # Wazuh Manager
curl -k https://192.168.10.20:443  # Dashboard Wazuh
```

—

Checklist Phase 1 — État final

Tâche	État
Installation Kali + Docker	☑️
Installation Nessus	☑️
Installation Exegol	☑️
Configuration réseau Kali (2 NICs)	☑️
Installation Ubuntu Hardened	☑️
SSH + UFW + Fail2Ban	☑️
Installation Wazuh Manager	☑️
Configuration Netplan & connectivité	☑️

Tâche	État
Installation OPNsense (2 interfaces)	☑️
Configuration LAN/WAN + NAT	☑️
Configuration client VPN Ubuntu	☑️
Tests VPN, ping, logs	☑️
Vérification connectivité globale	☑️
Snapshots VMware	☑️

Sources officielles

Outil	Documentation officielle
Docker	https://docs.docker.com/engine/install/
Nessus	https://www.tenable.com/downloads/nessus
Wazuh	https://documentation.wazuh.com/current/installation-guide/
Exegol	https://docs.exegol.com/first-install
OpenVPN	https://community.openvpn.net/openvpn/wiki/OpenVPNSoftwareRepos

—

Phase 2 — Sécurisation, supervision & tests d'attaque (16–20 juin)

› Objectifs globaux

- Appliquer le hardening système (pare-feu, SSH, Fail2Ban)
- Déployer la supervision Wazuh (manager + agents)
- Lancer des attaques simulées depuis Kali (brute-force, scan, DoS)
- Détecter les intrusions via Wazuh et Suricata
- Scanner les vulnérabilités et en corriger >90 %
- Valider les accès VPN sécurisés

—

› PC 1 — Red Team (Kali + Nessus + Exegol)

Rôle : Offensive — attaques réalistes pour tester la détection et auditer les systèmes.

Résultats scan Nessus — Ubuntu Hardened (192.168.10.10)

CVE	Vulnérabilité	Sévérité	Impact
—	ICMP Timestamp Response	badge(info-c, « BAS »)	Reconnaissance temporelle du système
—	TCP Timestamps	badge(info-c, « BAS »)	Révèle le uptime du système

CVE	Vulnérabilité	Sévérité	Impact
CVE-2000-1200	SSL Medium Strength Cipher Suites	badge(warning-c, « MOYEN »)	Suites de chiffrement faibles
CVE-2018-0734	SSL Certificate Signature Weak	badge(warning-c, « MOYEN »)	Algorithme MD5/SHA1 faible
CVE-2023-0464	OpenSSL Multiple Vulnerabilities	badge(danger, « ÉLEVÉ »)	Attaques distantes possibles
CVE-2023-0465	OpenSSL Timing Side Channel	badge(danger, « ÉLEVÉ »)	Canal auxiliaire sur OpenSSL
CVE-2023-2650	OpenSSH Privilege Escalation	badge(rgb(« 8 »), « CRITIQUE »)	Élévation de privilèges locale

Résultats scan Nessus — Wazuh Manager (192.168.10.20)

Sévérité	Vulnérabilité	Plugin	CVE(s)
badge(rgb(« 8 »),« CRITIQUE »)	Apache HTTP Server 2.4 < 2.4.57	173940	CVE-2023-25690, CVE-2023-27522
badge(rgb(« 8 »),« CRITIQUE »)	Apache HTTP/2 DoS — Rapid Reset Attack	181337	CVE-2023-44487
badge(danger,« ÉLEVÉ »)	Apache 2.4.7 < 2.4.57 Multi-Vuln	174373	CVE-2023-25690
badge(warning-c,« MOYEN »)	TLS 1.0 Protocol Detection	104743	—
badge(warning-c,« MOYEN »)	TLS 1.1 Protocol Detection	104743	—
badge(warning-c,« MOYEN »)	SSL Medium Strength Cipher Suites	42873	—
badge(info-c,« BAS »)	SSH Weak MAC Algorithms	70658	—
badge(info-c,« BAS »)	SSH CBC Mode Ciphers	70659	—
badge(info-c,« BAS »)	Apache ETag Header — Info Disclosure	104843	—
badge(info-c,« BAS »)	Apache Multiple Encodings	11936	—
badge(info-c,« BAS »)	HTTP Header Internal IP Disclosure	24260	—

Total : 11 vulnérabilités détectées. Priorité de correction : Critiques et Élevées (Apache HTTPD).

Recommandations post-scan

Désactiver ICMP timestamp (anti-fingerprinting) :

```
echo 1 > /proc/sys/net/ipv4/icmp_echo_ignore_all
```

Mettre à jour les paquets vulnérables :

```
sudo apt update && sudo apt upgrade -y
```

Renforcer SSH (`/etc/ssh/sshd_config`) :

```
MACs hmac-sha2-256,hmac-sha2-512
Ciphers aes256-ctr,aes192-ctr,aes128-ctr
```

Renforcer Apache (`ssl.conf`) : désactiver TLS 1.0/1.1, ETag, ciphers faibles.

Brute-force SSH avec Hydra

```
hydra -l user -P /usr/share/wordlists/rockyou.txt ssh://192.168.10.10 -s 22
```

Attaque **détectée et journalisée dans Wazuh** : alerte brute-force SSH générée en temps réel.

Scan Nmap — détection OS et services

```
nmap -sS -A 192.168.10.10
```

Tests avancés avec Exegol

```
exegol start
```

—

› PC 2 — Supervision et hardening

Rôle : Sécurisation + Supervision

SSH : Port 22, root désactivé, clé uniquement.

```
sudo ufw default deny incoming && sudo ufw default allow outgoing
sudo ufw allow 22/tcp && sudo ufw enable && sudo ufw status verbose
```

```
[sshd]
enabled = true
port = 22
maxretry = 3
bantime = 600
```

```
sudo systemctl restart fail2ban
```

Dashboard : `https://192.168.10.20:443` — catégories : Authentication, Network, System Audit.

```
sudo /var/ossec/bin/agent_control -l
tail -f /var/log/auth.log && tail -f /var/log/fail2ban.log
```

—

› PC 3 — OPNsense IDS/IPS

Suricata actif sur LAN — règles : `emerging-ssh`, `emerging-dos`, `emerging-scan`.

Alertes vérifiées :

- Brute-force SSH via Hydra ✅
- Ping flood ICMP via `hping3` ✅
- Tentatives de connexion anormales ✅

—

Checklist Phase 2 — État final

Tâche	État
Scan Nessus + rapport (×2)	☑️
Brute-force SSH + Nmap	☑️
Tests Exegol	☑️
Alertes Wazuh détectées	☑️
UFW + Fail2Ban actifs	☑️
IDS Suricata (OPNsense)	☑️
Logs firewall consultables	☑️
Connexion VPN fonctionnelle	☑️

Conclusion

Ce projet m'a permis d'appliquer concrètement les principes fondamentaux de la cybersécurité : **défense en profondeur**, gestion des vulnérabilités, supervision en temps réel et contrôle des accès.

Réalisation	Détail
✓ Architecture réseau	Segmentée et réaliste, OPNsense en cœur de réseau
✓ Serveur Ubuntu durci	UFW, Fail2Ban, SSH par clé, mises à jour auto
✓ Supervision Wazuh	Détection temps réel : brute-force, scans, logs
✓ Attaques simulées	Kali + Exegol + Nessus — toutes détectées
✓ VPN sécurisé	Accès par certificat, logs tracés, SI accessible

Réalisation	Détail
✓ Documentation complète	Rapport, scripts, configs, captures fournies

Résultats quantitatifs :

- Infrastructure déployée ✓ · Sécurisation effective ✓
- Vulnérabilités corrigées (>90 %) ✓ · Supervision opérationnelle ✓
- Accès VPN fonctionnel ✓ · Preuves et configurations livrées ✓

Ce projet a consolidé mon autonomie technique et ma rigueur dans la documentation. Il constitue une base solide pour tout déploiement futur en entreprise dans un contexte de cybersécurité open source.

« Un bon défenseur est celui qui sait attaquer. »

Dernière mise à jour : 27 juin 2025 · *HackMD original :* https://hackmd.io/@bkh/SkMid6M2gx